

**永豐金證券股份有限公司**  
**個人資料保護政策暨檔案安全維護辦法**

☐非因應外規訂定

☒因應外規訂定

制定單位：法令遵循處

核定層級：董事會

規章編號：法定/董/法遵/005

## **第一章 總則**

**第一條** 為個人資料管理、安全維護與執行，特依據「個人資料保護法」（以下簡稱「個資法」）、「金融監督管理委員會指定非公務機關個人資料檔案安全維護辦法」及「證券暨期貨市場各服務事業建立內部控制制度處理準則」第八條，訂定本辦法。

國外子公司個人資料之管理、維護與執行，依所在地政府法令辦理之。本公司之海外分支機構(含子公司)於不牴觸當地法令情況下，並應遵循本國「個人資料保護法」相關之法令。

**第二條** 本辦法所規範之事項，如因外部有關法令新增或修正者，於本辦法修正前，應依外部新增或修正後之規定辦理。

## **第二章 規範本公司之事項**

### **第一節 個人資料保護政策**

#### **第三條 保護範圍及安全措施**

本辦法所稱個人資料，係指自然人之姓名、生日、身分證號、護照號碼、聯絡方式、財務情況、社會活動、特徵、指紋、婚姻、家庭、教育、職業及特種個人資料，包括：病歷、醫療、基因、性生活、健康檢查、犯罪前科，及其他得以直接或間接方式識別該個人之資料。

本公司為防止個人資料被竊取、竄改、毀損、滅失或洩漏，應採取技術上及組織上之適當安全措施。適當之安全措施如下：

- 一、配置管理之人員及相當資源。
- 二、界定個人資料之範圍。
- 三、個人資料之風險評估及管理機制。
- 四、事故之預防、通報及應變機制。
- 五、個人資料蒐集、處理及利用之內部管理程序。
- 六、資料安全管理及人員管理。
- 七、認知宣導及教育訓練。
- 八、設備安全管理。
- 九、資料安全稽核機制。
- 十、使用紀錄、軌跡資料及證據保存。
- 十一、個人資料安全維護之整體持續改善。

#### 第 四 條 保密義務

本公司為維護所保有個人資料之安全，應依執行業務之必要，設定相關人員接觸個人資料之權限及控管其接觸情形，並與所屬人員約定保密義務。

#### 第 五 條 內部控制

本公司為確保本辦法之落實，應定期檢視、修訂本辦法等相關涉及個人資料保護之規章，並依業務規模及特性，衡酌經營資源之合理分配，訂定適當之個人資料安全稽核機制；並應將相關機制列入內部控制及稽核項目。

#### 第 六 條 個人資料之蒐集、處理及利用

各單位應確實遵循個資法之規定蒐集、處理及利用個人資料，並訂定個人資料取得之流程、審核、銷毀之規範。

當事人直接提供之個人資料，應依個資法規定於蒐集時履行告知義務；個資法施行前非由當事人提供之個人資料，應依個資法規定於首次利用時履行告知義務。

各單位委託他人蒐集、處理或利用個人資料者，除適用本辦法外，仍應遵守個資相關法令對委託機關之規定。

#### 第 七 條 蒐集之特定目的

本公司蒐集、處理或利用個人資料之特定目的及類別，參考法務部制定之「個人資料保護法之特定目的及個人資料之類別」為之。

本公司對於個人資料之蒐集或處理，應有特定目的並符合法令規定。除法定情形外，不得蒐集或處理特種個人資料。

本公司於個人資料之蒐集、處理或利用，應尊重當事人權益，依誠實及信用方法為之，不得逾越特定目的之必要範圍，並應與蒐集之目的具有正當合理之關聯。

本公司於揭露、轉介或交互運用客戶資料時，除法令另有規定、經客戶簽訂契約或書面明示同意者外，所揭露、轉介或交互運用之資料不得含有客戶姓名或地址以外之其他資料。

各單位對個人資料之蒐集、處理、利用，應符合相關法令，並依本公司相關內部規範辦理之，不得有任何牴觸內外部規定之情事。

#### 第 八 條 當事人行使權利

當事人請求行使查詢、閱覽、製給複製本、補充、更正、停止蒐集、處理及利用，或請求刪除個人資料之權利時，本公司應依個資法之規定辦理。

當事人請求查詢、閱覽或製給個人資料複製本者，本公司得酌收必要成本費用。

### 第 二 節 個人資料檔案安全維護

#### 第 九 條 個資管理單位

為落實個人資料之保護與管理，本公司組織上應設置個人資料保護管理執行小組（以下簡稱執行小組）。

執行小組置召集人一人，由總經理指定高階主管一人擔任，執行秘書一人及委員若干人，均由召集人指定之。

各單位就各自持有之個人資料負管理之責，並應依業務規模及特性，衡酌經營資源之合理分配，配置管理之人員及相當資源，以規劃與執行本辦法。

#### 第十條 執行小組任務

- 一、本公司個人資料保護政策之擬議。
- 二、本公司個人資料管理制度之推展。
- 三、本公司員工之個人資料保護意識提升及教育訓練計劃之擬議。
- 四、本公司個人資料管理制度基礎設施之評估。
- 五、本公司個人資料管理制度適法性與合宜性之檢視、審議及評估。
- 六、各單位執行本辦法產生爭議之解釋及裁決。
- 七、其他本公司個人資料保護、管理之規劃及執行事項。

#### 第十一條 執行小組運作

執行小組會議視業務推動之需要，不定期召開，由召集人主持；召集人因故不能主持會議時，得指定委員代理之。

執行小組會議開會時，得邀請業務相關單位人員出席。

#### 第十二條 安全維護原則

為防止個人資料被竊取、竄改、毀損、滅失或洩漏，本公司應依「金融監督管理委員會指定非公務機關個人資料檔案安全維護辦法」辦理個人資料檔案安全維護事項。

個人資料檔案應建立資料、設備安全管理制度，並依本公司所訂定之控管辦法就接觸人員建立安全控管機制。

#### 第十三條 個資盤點

本公司應每年辦理一次盤點查核，以確認所保有之個人資料現況，界定其納入本辦法之範圍。

#### 第十四條 風險評鑑

本公司應依前條界定之個人資料範圍及其業務涉及個人資料蒐集、處理、利用之流程，評估可能產生之風險，並根據風險評估之結果，檢討或調整本公司涉及個人資料之管理機制。

#### 第十五條 個人資料安全事故

本公司為因應發生個人資料之竊取、竄改、毀損、滅失或洩漏等安全事故(下稱事故)，應遵循下列應變、通報及預防機制：

- 一、事故發生後所採取之應變措施，應包括：
  - (一) 控制當事人損害之方式。
  - (二) 查明事故後通知當事人之適當方式。
  - (三) 應通知當事人事實、所為因應措施及諮詢服務專線等內容。



二、事故發生後通報之對象及通報方式應依本公司「緊急事件因應要點」辦理。

三、事故發生後，應研議矯正預防之機制或措施。

遇有個人資料檔案發生遭人惡意破壞毀損、作業不慎致發生危安事故、駭客攻擊或其他個人資料安全事故，相關權責單位應立即通報執行小組之召集人及執行秘書，並於二日內完成回報應變措施及處理方式(包括載明「控制當事人損害之方式」、「查明事故後通知當事人之方式」、「查明事故後通知當事人之內容」，並依本公司相關規範辦理。

前項個人資料安全事故，其矯正預防措施之研議機制應提報個人資料保護管理執行小組審議。

如屬重大個人資料安全事故者，應於七十二小時內填寫附件呈總經理核定並通知執行秘書通報金融監督管理委員會。但於其他法令另有規定時，並應依各該法令規定辦理。依第一項第三款所研議矯正預防之機制或措施，並應經公正、獨立且取得相關公認認證資格之專家，進行整體診斷及檢視。

前項所稱重大個人資料安全事故，係指個人資料遭竊取、竄改、毀損、滅失或洩漏，將危及本公司正常營運或大量當事人權益之情形。

#### 第十六條 個資外洩演練

本公司如有提供電子商務服務，其系統所採行「防止外部網路入侵對策」及「非法或異常使用行為之監控與因應機制」等資訊安全措施，應每年辦理一次演練及檢討改善。

#### 第十七條 自我評估報告

本公司為持續改善個人資料安全維護，各單位應每年提出一次自我評估報告，針對評估報告中有違反法令之虞者，規劃、執行改善及預防措施。

前項自我評估報告及改善預防措施，授權總經理核定，並定期提報董事會備查。

#### 第十八條 教育訓練

本公司對所屬人員應至少每年辦理一次個人資料保護認知宣導及教育訓練，使其明瞭相關法令之要求、所屬人員之責任範圍與各種個人資料保護事項之機制、程序及措施。

#### 第十九條 留存軌跡

本公司執行本辦法所定各種個人資料保護機制、程序及措施，應記錄其個人資料使用情況，留存軌跡資料或相關證據。

本公司依個資法規定刪除、停止處理或利用所保有之個人資料後，應留存下列紀錄：

一、刪除、停止處理或利用之方法、時間。

二、將刪除、停止處理或利用之個人資料移轉其他對象者，其移轉之原因、對象、方法、時間，及該對象蒐集、處理或利用之合法依據。

前二項之軌跡資料、相關證據及紀錄，應至少留存五年；但法令另有規定或契約另有約定者，不在此限。

### 第 三 節 業務終止後個人資料處理

第 二十 條 本公司之業務終止係指本公司營業項目之一部或全部終止，並包括業務移轉至另一機構。

業務終止後個人資料不得再依原特定目的蒐集、處理、利用；除本公司或法令另有規定外，應依以下程序辦理：

一、移轉：

(一)繕製個人資料檔案移轉清冊一式二份，內容應包含個人資料名稱、檔案資料內容、檔案型態、移交資料總筆數、移交之卷夾數量/電子(系統)檔案容量、清點結果、移交人、接收人及監交人簽章等欄位。

(二)由本公司與受移轉機構，依個人資料檔案移轉清冊內容逐一進行清點、核對，並於點收完成後由本公司移交代表、受移轉機構接收代表及監交人於相關欄位中進行簽章。

(三)完成清點之個人資料檔案移轉清冊應加蓋本公司及受移轉機構公司印鑑章後，各自收執保留一份。

(四)本公司負責移交單位於完成上述個人資料移轉程序後，應將個人資料檔案移轉清冊歸檔備存。

二、銷毀：業務終止後個人資料之銷毀，應依本公司銷毀之相關規定辦理。

### 第 三 章 附則（法規優先適用原則）

第二十一條 本辦法第一條之法律或函令依據詳如附錄，附錄為本辦法之一部份，如因該法律或函令修正時，授權制定單位自行更新本辦法之附錄，並按月提董事會備查。

第二十二條 本辦法經董事會決議通過後施行，修正時亦同。

中華民國一〇五年八月三十一日第十屆董事會一〇五年第十二次會議通過

中華民國一〇六年十一月二十九日第十屆董事會一〇六年第十六次會議通過

中華民國一一一年三月三十日第十二屆董事會一一一年第四次會議修正通過

附錄

法令全文

一、法規

| 制定單位、<br>法規名稱、<br>條次 | 最新修正日期<br>(如法規已廢止<br>須註明) | 條文全文(重要處以底線表示)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|----------------------|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 個人資料保<br>護法          | <u>112年5月31日</u><br>修正    | <p><b>第 2 條</b></p> <p>本法用詞，定義如下：</p> <p>一、個人資料：指自然人之姓名、出生年月日、國民身分證統一編號、護照號碼、特徵、指紋、婚姻、家庭、教育、職業、病歷、醫療、基因、性生活、健康檢查、犯罪前科、聯絡方式、財務情況、社會活動及其他得以直接或間接方式識別該個人之資料。</p> <p>二、個人資料檔案：指依系統建立而得以自動化機器或其他非自動化方式檢索、整理之個人資料之集合。</p> <p>三、蒐集：指以任何方式取得個人資料。</p> <p>四、處理：指為建立或利用個人資料檔案所為資料之記錄、輸入、儲存、編輯、更正、複製、檢索、刪除、輸出、連結或內部傳送。</p> <p>五、利用：指將蒐集之個人資料為處理以外之使用。</p> <p>六、國際傳輸：指將個人資料作跨國（境）之處理或利用。</p> <p>七、公務機關：指依法行使公權力之中央或地方機關或行政法人。</p> <p>八、非公務機關：指前款以外之自然人、法人或其他團體。</p> <p>九、當事人：指個人資料之本人。</p> <p><b>第 3 條</b></p> <p>當事人就其個人資料依本法規定行使之下列權利，不得預先拋棄或以特約限制之：</p> <p>一、查詢或請求閱覽。</p> <p>二、請求製給複製本。</p> <p>三、請求補充或更正。</p> <p>四、請求停止蒐集、處理或利用。</p> <p>五、請求刪除。</p> <p><b>第 4 條</b></p> <p>受公務機關或非公務機關委託蒐集、處理或利用個人資料者，於本法適用範圍內，視同委託機關。</p> <p><b>第 5 條</b></p> <p>個人資料之蒐集、處理或利用，應尊重當事人之權益，依誠實及信用方法為之，不得逾越特定目的之必要範圍，並應與蒐集之目的具有正當合理之關聯。</p> <p><b>第 6 條</b></p> <p>有關病歷、醫療、基因、性生活、健康檢查及犯罪前科之個人資料，不得 蒐集、處理或利用。但有下列情形之一者，不在此限：</p> <p>一、法律明文規定。</p> <p>二、公務機關執行法定職務或非公務機關履行法定義務必要範圍內，且事 前或事後有適當安全維護措施。</p> <p>三、當事人自行公開或其他已合法公開之個人資料。</p> <p>四、公務機關或學術研究機構基於醫療、衛生或犯罪預防之目的，為統計 或學術研究而有必要，且資料經過提供者處理後或經蒐集者依其揭露 方式無從識別特定之當事人。</p> <p>五、為協助公務機關執行法定職務或非公務機關履行法定義務必要範圍內，且事前或事後有適當安全維護措施。</p> |



六、經當事人書面同意。但逾越特定目的之必要範圍或其他法律另有限制 不得僅依當事人書面同意蒐集、處理或利用，或其同意違反其意願者，不在此限。

依前項規定蒐集、處理或利用個人資料，準用第八條、第九條規定；其中 前項第六款之書面同意，準用第七條第一項、第二項及第四項規定，並以 書面為之。

#### 第 7 條

第十五條第二款及第十九條第一項第五款所稱同意，指當事人經蒐集者告知本法所定應告知事項後，所為允許之意思表示。

第十六條第七款、第二十條第一項第六款所稱同意，指當事人經蒐集者明確告知特定目的外之其他利用目的、範圍及同意與否對其權益之影響後，單獨所為之意思表示。

公務機關或非公務機關明確告知當事人第八條第一項各款應告知事項時，當事人如未表示拒絕，並已提供其個人資料者，推定當事人已依第十五條第二款、第十九條第一項第五款之規定表示同意。

蒐集者就本法所稱經當事人同意之事實，應負舉證責任。

#### 第 8 條

公務機關或非公務機關依第十五條或第十九條規定向當事人蒐集個人資料時，應明確告知當事人下列事項：

- 一、公務機關或非公務機關名稱。
- 二、蒐集之目的。
- 三、個人資料之類別。
- 四、個人資料利用之期間、地區、對象及方式。
- 五、當事人依第三條規定得行使之權利及方式。
- 六、當事人得自由選擇提供個人資料時，不提供將對其權益之影響。

有下列情形之一者，得免為前項之告知：

- 一、依法律規定得免告知。
- 二、個人資料之蒐集係公務機關執行法定職務或非公務機關履行法定義務所必要。
- 三、告知將妨害公務機關執行法定職務。
- 四、告知將妨害公共利益。
- 五、當事人明知應告知之內容。
- 六、個人資料之蒐集非基於營利之目的，且對當事人顯無不利之影響。

#### 第 9 條

公務機關或非公務機關依第十五條或第十九條規定蒐集非由當事人提供之個人資料，應於處理或利用前，向當事人告知個人資料來源及前條第一項第一款至第五款所列事項。

有下列情形之一者，得免為前項之告知：

- 一、有前條第二項所列各款情形之一。
- 二、當事人自行公開或其他已合法公開之個人資料。
- 三、不能向當事人或其法定代理人為告知。
- 四、基於公共利益為統計或學術研究之目的而有必要，且該資料須經提供者處理後或蒐集者依其揭露方式，無從識別特定當事人者為限。
- 五、大眾傳播業者基於新聞報導之公益目的而蒐集個人資料。

第一項之告知，得於首次對當事人為利用時併同為之。

#### 第 10 條

公務機關或非公務機關應依當事人之請求，就其蒐集之個人資料，答覆查詢、提供閱覽或製給複製本。但有下列情形之一者，不在此限：

- 一、妨害國家安全、外交及軍事機密、整體經濟利益或其他國家重大利益。
- 二、妨害公務機關執行法定職務。
- 三、妨害該蒐集機關或第三人之重大利益。

**第 11 條**

公務機關或非公務機關應維護個人資料之正確，並應主動或依當事人之請求更正或補充之。

個人資料正確性有爭議者，應主動或依當事人之請求停止處理或利用。但因執行職務或業務所必須，或經當事人書面同意，並經註明其爭議者，不在此限。

個人資料蒐集之特定目的消失或期限屆滿時，應主動或依當事人之請求，刪除、停止處理或利用該個人資料。但因執行職務或業務所必須或經當事人書面同意者，不在此限。

違反本法規定蒐集、處理或利用個人資料者，應主動或依當事人之請求，刪除、停止蒐集、處理或利用該個人資料。

因可歸責於公務機關或非公務機關之事由，未為更正或補充之個人資料，應於更正或補充後，通知曾提供利用之對象。

**第 12 條**

公務機關或非公務機關違反本法規定，致個人資料被竊取、洩漏、竄改或其他侵害者，應查明後以適當方式通知當事人。

**第 19 條**

非公務機關對個人資料之蒐集或處理，除第六條第一項所規定資料外，應有特定目的，並符合下列情形之一者：

一、法律明文規定。

二、與當事人有契約或類似契約之關係，且已採取適當之安全措施。

三、當事人自行公開或其他已合法公開之個人資料。

四、學術研究機構基於公共利益為統計或學術研究而有必要，且資料經過提供者處理後或經蒐集者依其揭露方式無從識別特定之當事人。

五、經當事人同意。

六、為增進公共利益所必要。

七、個人資料取自於一般可得之來源。但當事人對該資料之禁止處理或利用，顯有更值得保護之重大利益者，不在此限。

八、對當事人權益無侵害。

蒐集或處理者知悉或經當事人通知依前項第七款但書規定禁止對該資料之處理或利用時，應主動或依當事人之請求，刪除、停止處理或利用該個人資料。

**第 20 條**

非公務機關對個人資料之利用，除第六條第一項所規定資料外，應於蒐集之特定目的必要範圍內為之。但有下列情形之一者，得為特定目的外之利用：

一、法律明文規定。

二、為增進公共利益所必要。

三、為免除當事人之生命、身體、自由或財產上之危險。

四、為防止他人權益之重大危害。

五、公務機關或學術研究機構基於公共利益為統計或學術研究而有必要，且資料經過提供者處理後或經蒐集者依其揭露方式無從識別特定之當事人。

六、經當事人同意。

七、有利於當事人權益。

非公務機關依前項規定利用個人資料行銷者，當事人表示拒絕接受行銷時，應即停止利用其個人資料行銷。

非公務機關於首次行銷時，應提供當事人表示拒絕接受行銷之方式，並支付所需費用。

**第 27 條**

非公務機關保有個人資料檔案者，應採行適當之安全措施，防止個人資料被竊取、竄改、毀損、滅失或洩漏。



|                              |                   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|------------------------------|-------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                              |                   | <p>中央目的事業主管機關得指定非公務機關訂定個人資料檔案安全維護計畫或業務終止後個人資料處理方法。</p> <p>前項計畫及處理方法之標準等相關事項之辦法，由中央目的事業主管機關定之。</p> <p><b>第 54 條</b></p> <p>本法中華民國九十九年五月二十六日修正公布之條文施行前，非由當事人提供之個人資料，於本法一百零四年十二月十五日修正之條文施行後為處理或利用者，應於處理或利用前，依第九條規定向當事人告知。</p> <p>前項之告知，得於本法中華民國一百零四年十二月十五日修正之條文施行後首次利用時併同為之。</p> <p>未依前二項規定告知而利用者，以違反第九條規定論處。</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| 金融監督管理委員會指定非公務機關個人資料檔案安全維護辦法 | 110 年 12 月 14 日修正 | <p><b>第 1 條</b></p> <p>本辦法依個人資料保護法（以下簡稱本法）第二十七條第三項規定訂定之。</p> <p><b>第 2 條</b></p> <p>本辦法所稱非公務機關，包括下列各款：</p> <ol style="list-style-type: none"> <li>一、金融控股公司。</li> <li>二、銀行業。</li> <li>三、證券業。</li> <li>四、期貨業。</li> <li>五、保險業。</li> <li>六、電子支付機構。</li> <li>七、其他經金融監督管理委員會（以下簡稱本會）公告之金融服務業。</li> <li>八、本會主管之財團法人。</li> </ol> <p>前項第一款所稱金融控股公司，依金融控股公司法第四條第一項第二款之規定。</p> <p>第一項第二款至第五款所稱銀行業、證券業、期貨業及保險業之範圍，依金融監督管理委員會組織法第二條第三項規定。但不包括依信用合作社法第十條規定組織之全國性信用合作社聯合社。</p> <p>第一項第六款所稱電子支付機構，依電子支付機構管理條例第三條第一款規定。</p> <p>第一項第八款所稱本會主管之財團法人，指本會成立前經財政部與其所屬機關許可設立隨業務移撥本會及本會許可設立之財團法人。</p> <p><b>第 3 條</b></p> <p>非公務機關應依其業務規模及特性，衡酌經營資源之合理分配，配置管理之人員及相當資源，以規劃、訂定、修正與執行其個人資料檔案安全維護計畫及業務終止後個人資料處理方法（以下簡稱本計畫及處理方法）。</p> <p>本計畫及處理方法之訂定或修正，應經非公務機關董（理）事會、常務董（理）事會決議或經其授權之經理部門核定。但非公務機關為外國在臺分行、分公司，或未設董（理）事會者，應經其負責人簽署。</p> <p><b>第 4 條</b></p> <p>非公務機關應依個人資料保護相關法令，定期查核確認所保有之個人資料現況，界定其納入本計畫及處理方法之範圍。</p> <p><b>第 5 條</b></p> <p>非公務機關應依前條界定之個人資料範圍及其業務涉及個人資料蒐集、處理、利用之流程，評估可能產生之個人資料風險，並根據風險評估之結果，訂定適當之管理機制。</p> <p><b>第 6 條</b></p> <p>非公務機關為因應個人資料之竊取、竄改、毀損、滅失或洩漏等安全事故（以下簡稱事故），應訂定下列應變、通報及預防機制：</p> <ol style="list-style-type: none"> <li>一、事故發生後應採取之各類措施，包括： <ol style="list-style-type: none"> <li>（一）控制當事人損害之方式。</li> <li>（二）查明事故後通知當事人之適當方式。</li> <li>（三）應通知當事人事實、所為因應措施及諮詢服務專線等內容。</li> </ol> </li> <li>二、事故發生後應受通報之對象及其通報方式。</li> <li>三、事故發生後，其矯正預防措施之研議機制。</li> </ol> <p>非公務機關遇有重大個人資料事故者，應依附件格式於七十二小時內通報本會。但於其他法令另有規定時，並應依各該法令之規定辦理。依前項第三款所研議之矯正預防措</p> |

施，並應經公正、獨立且取得相關公認認證資格之專家，進行整體診斷及檢視。  
前項所稱重大個人資料事故，係指個人資料遭竊取、竄改、毀損、滅失或洩漏，將危及非公務機關正常營運或大量當事人權益之情形。

本會接受非公務機關依第二項通報後，得依本法第二十二條至第二十五條等規定，為適當之監督管理措施。

#### **第 7 條**

非公務機關應定期對所屬人員，施以個人資料保護認知宣導及教育訓練，使其明瞭相關法令之要求、所屬人員之責任範圍與各種個人資料保護事項之機制、程序及措施。

#### **第 8 條**

非公務機關應就下列事項，訂定個人資料之管理程序：

- 一、蒐集、處理或利用之個人資料包含本法第六條所定特種個人資料者，檢視其特定目的及是否符合相關法令之要件；其經當事人書面同意者，並應確保符合本法第六條第二項準用第七條第一項、第二項及第四項之規定。
- 二、檢視個人資料之蒐集、處理，是否符合免為告知之事由，及告知之內容、方式是否合法妥適。
- 三、檢視一般個人資料之蒐集、處理，是否符合本法第十九條規定，具有特定目的及法定情形；其經當事人同意者，並應確保符合本法第七條之規定。
- 四、檢視一般個人資料之利用，是否符合本法第二十條規定蒐集之特定目的必要範圍；其為特定目的外之利用者，檢視是否符合法定情形，經當事人同意者，並應確保符合本法第七條之規定。
- 五、利用個人資料為行銷，當事人表示拒絕行銷者，立即停止利用其個人資料行銷，並至少於首次行銷時，提供當事人免費表示拒絕接受行銷之方式。
- 六、委託他人蒐集、處理或利用個人資料之全部或一部時，對受託人依本法施行細則第八條規定為適當之監督，並於委託契約或相關文件中，明確約定其內容。
- 七、進行個人資料國際傳輸前，檢視是否受本會限制並遵循之。
- 八、當事人行使本法第三條所定權利之相關事項：
  - (一) 當事人身分之確認。
  - (二) 提供當事人行使權利之方式，並告知所需支付之費用，及應釋明之事項。
  - (三) 對當事人請求之審查方式，並遵守本法有關處理期限之規定。
  - (四) 有本法所定得拒絕當事人行使權利之事由者，其理由記載及通知當事人之方式。
- 九、檢視個人資料於蒐集、處理或利用過程中是否正確；其有不正確或正確性有爭議者，應依本法第十一條第一項、第二項及第五項規定辦理。
- 十、檢視所保有個人資料之特定目的是否消失，或期限是否屆滿；其特定目的消失或期限屆滿者，應依本法第十一條第三項規定刪除、停止處理或利用。

#### **第 9 條**

非公務機關為維護所保有個人資料之安全，應採取下列資料安全管理措施：

- 一、訂定各類設備或儲存媒體之使用規範，及報廢或轉作他用時，應採取防範資料洩漏之適當措施。
- 二、針對所保有之個人資料內容，有加密之需要者，於蒐集、處理或利用時，採取適當之加密措施。
- 三、作業過程有備份個人資料之需要時，對備份資料予以適當保護。

#### **第 10 條**

非公務機關提供電子商務服務系統，應採取下列資訊安全措施：

- 一、使用者身分確認及保護機制。
- 二、個人資料顯示之隱碼機制。
- 三、網際網路傳輸之安全加密機制。
- 四、應用系統於開發、上線、維護等各階段軟體驗證與確認程序。
- 五、個人資料檔案及資料庫之存取控制與保護監控措施。

|                                    |                  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|------------------------------------|------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                    |                  | <p>六、防止外部網路入侵對策。</p> <p>七、非法或異常使用行為之監控與因應機制。</p> <p>前項所稱電子商務，係指透過網際網路進行有關商品或服務之廣告、行銷、供應、訂購或遞送等各項商業交易活動。</p> <p>第一項第六款、第七款所定措施，應定期演練及檢討改善。</p> <p><b>第 11 條</b></p> <p>非公務機關保有之個人資料存在於紙本、磁碟、磁帶、光碟片、微縮片、積體電路晶片、電腦、自動化機器設備或其他媒介物者，應採取下列設備安全管理措施：</p> <p>一、實施適宜之存取管制。</p> <p>二、訂定妥善保管媒介物之方式。</p> <p>三、依媒介物之特性及其環境，建置適當之保護設備或技術。</p> <p><b>第 12 條</b></p> <p>非公務機關為維護所保有個人資料之安全，應依執行業務之必要，設定相關人員接觸個人資料之權限及控管其接觸情形，並與所屬人員約定保密義務。</p> <p><b>第 13 條</b></p> <p>非公務機關為確保本計畫及處理方法之落實，應依其業務規模及特性，衡酌經營資源之合理分配，訂定適當之個人資料安全稽核機制；其依法令規定應建立內部控制及稽核制度者，並應將相關機制列入內部控制及稽核項目。</p> <p><b>第 14 條</b></p> <p>非公務機關執行本計畫及處理方法所定各種個人資料保護機制、程序及措施，應記錄其個人資料使用情況，留存軌跡資料或相關證據。</p> <p>非公務機關依本法第十一條第三項規定刪除、停止處理或利用所保有之個人資料後，應留存下列紀錄：</p> <p>一、刪除、停止處理或利用之方法、時間。</p> <p>二、將刪除、停止處理或利用之個人資料移轉其他對象者，其移轉之原因、對象、方法、時間，及該對象蒐集、處理或利用之合法依據。</p> <p>前二項之軌跡資料、相關證據及紀錄，應至少留存五年。但法令另有規定或契約另有約定者，不在此限。</p> <p><b>第 15 條</b></p> <p>非公務機關為持續改善個人資料安全維護，其所屬個人資料管理單位或人員，應定期提出相關自我評估報告，並訂定下列機制：</p> <p>一、檢視、修訂本計畫及處理方法等相關個人資料保護事項。</p> <p>二、針對評估報告中有違反法令之虞者，規劃、執行改善及預防措施。</p> <p>前項自我評估報告，應經非公務機關董（理）事會、常務董（理）事會決議或經其授權之經理部門核定。但非公務機關為外國在臺分行、分公司，或未設董（理）事會者，應經其負責人簽署。</p> <p><b>第 16 條</b></p> <p>本辦法自發布日施行。</p> |
| 證券暨期貨市場各服務事業建立內部控制制度處理準則第 8 條第 1 項 | 113 年 4 月 22 日修正 | <p>各服務事業之內部控制制度，除視事業之性質訂定各種營運循環類型之控制作業外，尚應視其需要包括對下列作業之控制：</p> <p>一、印鑑使用之管理。</p> <p>二、票據領用之管理。</p> <p>三、預算之管理。</p> <p>四、財產之管理。</p> <p>五、背書保證之管理。</p> <p>六、負債承諾及或有事項之管理。</p> <p>七、職務授權及代理人制度之執行。</p> <p>八、財務及非財務資訊之管理。</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |



|  |  |                                                                                                                                                                                                                                                                                                                                                           |
|--|--|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  |  | <p>九、關係人交易之管理。</p> <p>十、財務報表編製流程之管理，包括適用國際財務報導準則之管理、會計專業判斷程序、會計政策與估計<u>值</u>變動之流程等。</p> <p>十一、對子公司之監督與管理。</p> <p>十二、法令遵循制度。</p> <p>十三、金融檢查報告之管理。</p> <p>十四、金融消費者保護之管理。但依金融消費者保護法第三條第二項排除適用之事業，不在此限。</p> <p>十五、<u>客戶資料保密</u>。</p> <p>十六、重大事件（如：重大違規、遭受重大損失之虞等）處理及通報機制之管理。</p> <p>十七、檢舉制度。</p> <p><u>十八、作業委託他人處理之管理。</u></p> <p><u>十九、其他經主管機關指定之事項。</u></p> |
|--|--|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

版本更新日：113 年 9 月 10 日更新證券暨期貨市場各服務事業建立內部控制制度處理準則第 8 條第 1 項第 10 款、第 15 款、第 18 款及第 19 款條文。

## 個人資料侵害事故通報與紀錄表

|                         |                                                                                                                                                                                            |                                                                    |
|-------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------|
| 非公務機關名稱：                | 通報時間： 年 月 日 時 分                                                                                                                                                                            |                                                                    |
| 通報機關：                   | 通報人： 簽名(蓋章)                                                                                                                                                                                |                                                                    |
|                         | 職稱：                                                                                                                                                                                        |                                                                    |
|                         | 電話：                                                                                                                                                                                        |                                                                    |
|                         | Email：                                                                                                                                                                                     |                                                                    |
|                         | 地址：                                                                                                                                                                                        |                                                                    |
| 事件發生時間                  |                                                                                                                                                                                            |                                                                    |
| 事件發生種類                  | <input type="checkbox"/> 竊取<br><input type="checkbox"/> 洩漏<br><input type="checkbox"/> 竄改<br><input type="checkbox"/> 毀損<br><input type="checkbox"/> 滅失<br><input type="checkbox"/> 其他侵害事故 | 個資侵害之總筆數(約)<br>筆                                                   |
|                         |                                                                                                                                                                                            | <input type="checkbox"/> 一般個資 筆<br><input type="checkbox"/> 特種個資 筆 |
| 發生原因及事件摘要               |                                                                                                                                                                                            |                                                                    |
| 損害狀況                    |                                                                                                                                                                                            |                                                                    |
| 個資外洩可能結果                |                                                                                                                                                                                            |                                                                    |
| 擬採取之因應措施                |                                                                                                                                                                                            |                                                                    |
| 擬採通知當事人之時間及方式           |                                                                                                                                                                                            |                                                                    |
| 是否於發現個資外洩後<br>72 小時通報本會 | <input type="checkbox"/> 是<br><input type="checkbox"/> 否，理由：                                                                                                                               |                                                                    |

註1：各欄位資訊若尚未明確，得先填寫「不明」，並俟明確後再通報更新補充。

註2：請於72小時通報金融監督管理委員會，例假日均納入時效計算。